

=====

BUMPASS FIRE & RESCUE
CRYPTOGRAPHIC PASSWORD PROTECTION POLICY

=====

Document ID: POL-IA-010
Version: 1.0
Effective Date: April 20, 2026
Review Date: April 20, 2027
Owner: Mike Sadler, IT Administrator
Approved By: Chief Randy Bowles

=====

1. PURPOSE

This policy requires that passwords are stored and transmitted using cryptographic protections to prevent unauthorized disclosure or use of credentials.

2. PASSWORD STORAGE REQUIREMENTS

2.1 Active Directory

- Passwords are stored as one-way salted hashes (NTLM and Kerberos hash formats) in the AD database (NTDS.dit)
- Reversible encryption is DISABLED (password cannot be recovered from stored hash)
- NTDS.dit is protected by DPAPI and encrypted on disk

2.2 Azure AD

- Password hashes are synced via Azure AD Connect using Password Hash Synchronization (PHS)
- Hashes are stored as bcrypt-equivalent double-hashed format in Microsoft's Azure AD infrastructure

2.3 Application Passwords

- No application stores plaintext passwords
- Service account passwords stored in Azure Key Vault (encrypted at rest, access logged)

3. PASSWORD TRANSMISSION

- All authentication over the network uses Kerberos (ticket-based - actual password never transmitted)
- Web-based auth uses HTTPS/TLS 1.2+ (never HTTP)
- LDAP binds: LDAPS (port 636) only; no LDAP clear text

4. PROHIBITED

- Plaintext password storage in any file, spreadsheet, or note
- HTTP-based authentication forms
- Simple bind (LDAP over port 389 without TLS)

=====

Approved: Chief Randy Bowles 04/20/2026
Prepared: Mike Sadler 04/18/2026

=====